

安全加固报告 FIX-04：CSRF跨站请求伪造

修复漏洞类型：CSRF跨站请求伪造

修复小组：天亮了么

修复时间：2026-08-23

对应漏洞报告：VULN-04-CSRF跨站请求伪造

修复负责人：蒲云楷

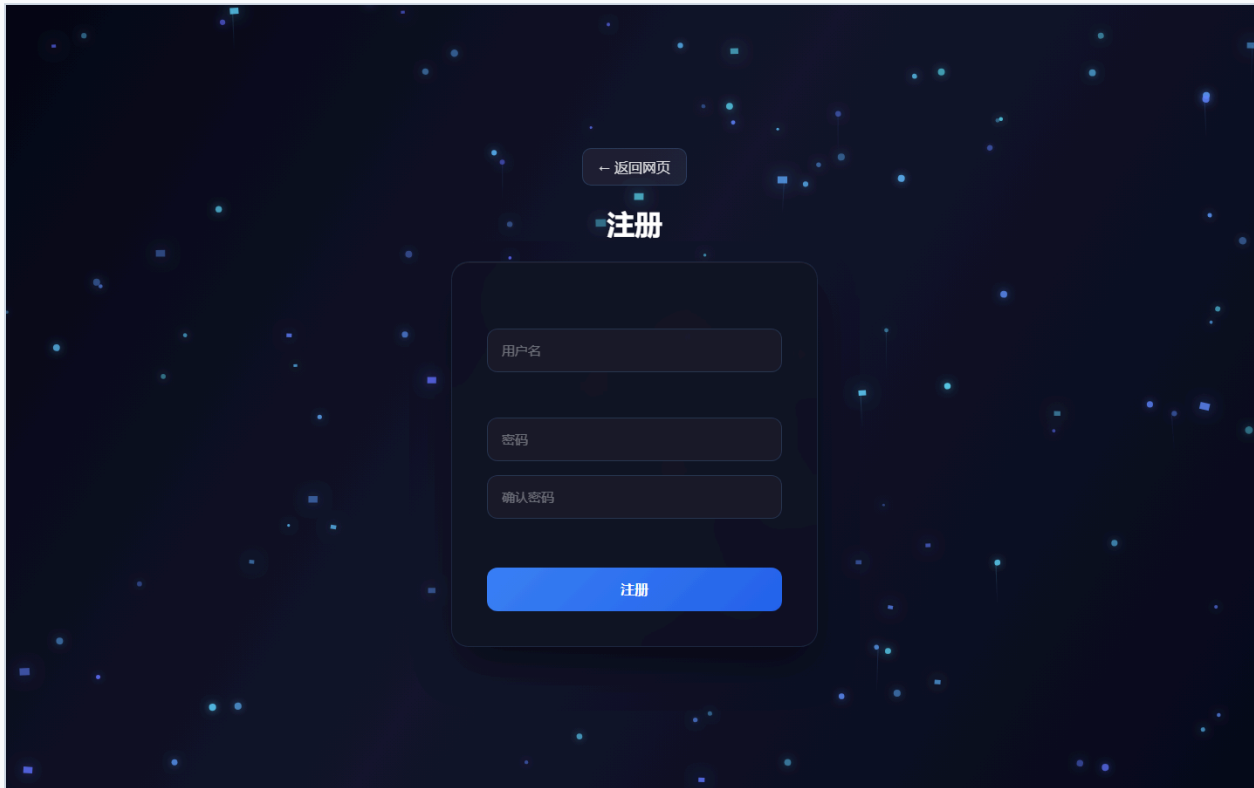
1. 基本信息

本报告按附录A记录阶段二任务4的修复和验证。

2. 漏洞复现情况

是否能按攻击方步骤复现：修复前基线已记录；修复后原始参数应被拦截或不产生越权效果。

复现环境：本机 127.0.0.1:5001。



Pretty-print ☐

```
[{"error": "\u8bf7\u6c42\u9a8c\u8bc1\u5931\u8d25\u5f0c\u8bf7\u5237\u65b0\u9875\u9762\u540e\u91cd\u8bd5"}]
```

上传文件

选择文件

Choose File

No file chosen

可选新文件名

留空则使用原文件名

上传文件

返回个人主页

Pretty-print ☐

```
["csrf_token": "kuzklbuH5MLtODPBxM5yLI0I5DVpZorqbEJgBVwqZGA"]
```

任务 04 修复代码证据

gets.py:64-90

```
64
65
66 def csrf_token():
67     token = session.get("csrf_token")
68     if not token:
69         token = secrets.token_urlsafe(32)
70         session["csrf_token"] = token
71     return token
72
73
74 @app.context_processor
75 def inject_security_helpers():
76     return {'csrf_token': csrf_token}
77
78
79 def csrf_protected(view):
80     @wraps(view)
81     def wrapped(*args, **kwargs):
82         supplied = request.form.get("csrf_token") or request.headers.get("X-CSRF-Token")
83         expected = session.get("csrf_token")
84         if not expected or not supplied or not secrets.compare_digest(supplied, expected):
85             return jsonify({'error': "请求验证失败，请刷新页面后重试"}), 403
86         return view(*args, **kwargs)
87
88     return wrapped
89
90
```

gets.py:302-320

```
302 @csrf_protected
303 def api_register():
304     data = request.get_json(silent=True) or request.form
305     return _register(data.get("username", "").strip(), data.get("password", ""), data.get("confirm_password", ""))
306
307
308 @app.route("/upload", methods=["GET", "POST"])
309 def upload_file():
310     if "username" not in session:
311         return redirect("/login")
312     if request.method == "GET":
313         return render_template("upload.html")
314     supplied = request.form.get("csrf_token")
315     if not supplied or not secrets.compare_digest(supplied, session.get("csrf_token", "")):
316         return jsonify({'error': "请求验证失败，请刷新页面后重试"}), 403
317     result = _save_upload(request.files.get("file"), request.form.get("customName", ""))
318     return redirect("/listfiles") if result[1] == 200 else result
319
320
```

3. 根因定位

相关文件：gets.py、相关模板和前端 API 客户端。

相关函数或接口：登录、注册、上传、删除及 API 状态变更接口。

问题代码/根因：原状态变更接口未统一校验请求来源。

4. 修复措施

修改点1

修改文件：gets.py。

修改前逻辑：缺少统一安全边界或校验。

修改后逻辑：Session 生成随机 Token；表单 hidden 字段和 X-CSRF-Token 请求头统一校验；Cookie 使用 SameSite=Lax。

修改点2

修改文件：相关 HTML/CSS/前端 API（按任务适用）。

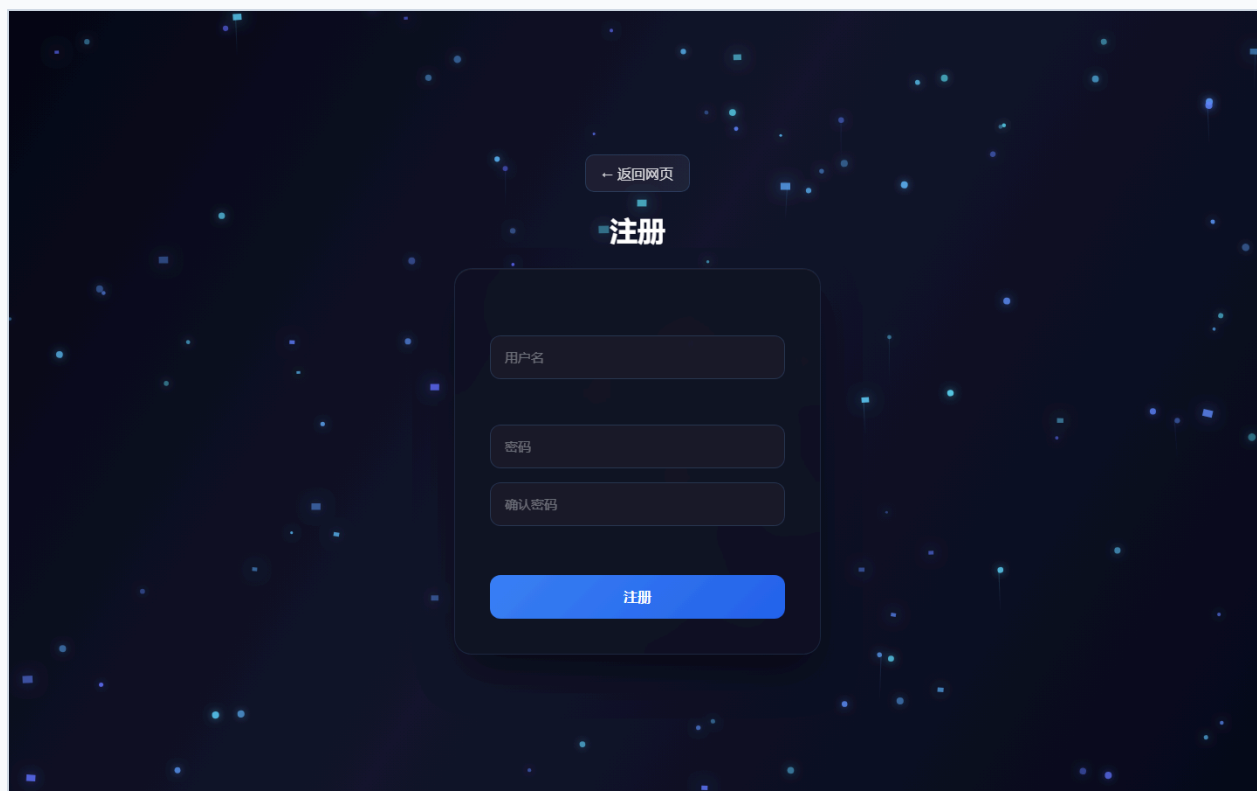
修改后逻辑：页面和客户端与服务端安全校验保持一致，不能替代服务端校验。

5. 修复后验证

使用攻击方原始步骤重新测试：

1. 发送原始无害测试参数。
2. 观察状态码、页面、数据、文件和日志。
3. 确认原攻击失效并保存截图。

验证结果：不携带 CSRF Token 调用 /api/register，返回403；错误 Token 的上传请求也被拒绝。
原攻击是否失效：是（本机回归测试）



Pretty-print ☐

```
[{"error": "\u8bf7\u6c42\u9a8c\u8bc1\u5931\u8d25\u5f0c\u8bf7\u5237\u65b0\u9075\u9762\u540e\u91cd\u8bd5"}]
```

上传文件

选择文件

Choose File

No file chosen

可选新文件名

留空则使用原文件名

上传文件

返回个人主页

Pretty-print ☐

```
{"csrf_token": "kuzklbuH5MLtODPBxM5yLI0I5DVpZorqbEJgBVwqZGA"}
```

任务 04 修复代码证据

gets.py:64-90

```
64
65
66 def csrf_token():
67     token = session.get("csrf_token")
68     if not token:
69         token = secrets.token_urlsafe(32)
70         session["csrf_token"] = token
71     return token
72
73
74 @app.context_processor
75 def inject_security_helpers():
76     return {'csrf_token': csrf_token}
77
78
79 def csrf_protected(view):
80     @wraps(view)
81     def wrapped(*args, **kwargs):
82         supplied = request.form.get("csrf_token") or request.headers.get("X-CSRF-Token")
83         expected = session.get("csrf_token")
84         if not expected or not supplied or not secrets.compare_digest(supplied, expected):
85             return jsonify({'error': "请求验证失败，请刷新页面后重试"}), 403
86         return view(*args, **kwargs)
87
88     return wrapped
89
90
```

gets.py:302-320

```
302 @csrf_protected
303 def api_register():
304     data = request.get_json(silent=True) or request.form
305     return _register(data.get("username", "").strip(), data.get("password", ""), data.get("confirm_password", ""))
306
307
308 @app.route("/upload", methods=["GET", "POST"])
309 def upload_file():
310     if "username" not in session:
311         return redirect("/login")
312     if request.method == "GET":
313         return render_template("upload.html")
314     supplied = request.form.get("csrf_token")
315     if not supplied or not secrets.compare_digest(supplied, session.get("csrf_token", "")):
316         return jsonify({'error': "请求验证失败，请刷新页面后重试"}), 403
317     result = _save_upload(request.files.get("file"), request.form.get("customName", ""))
318     return redirect("/listfiles") if result[1] == 200 else result
319
320
```

6. 额外加固

统一错误提示、输入长度限制、安全日志、Cookie 安全属性、调试模式关闭和生产密钥配置要求。

7. 仍需改进

课程组别、负责人、Git tag 等元数据需在提交前填写；HTTPS 部署时启用 Secure Cookie；Web 服务器需确认上传目录不可执行。